

TH3 : CH4 : TD1

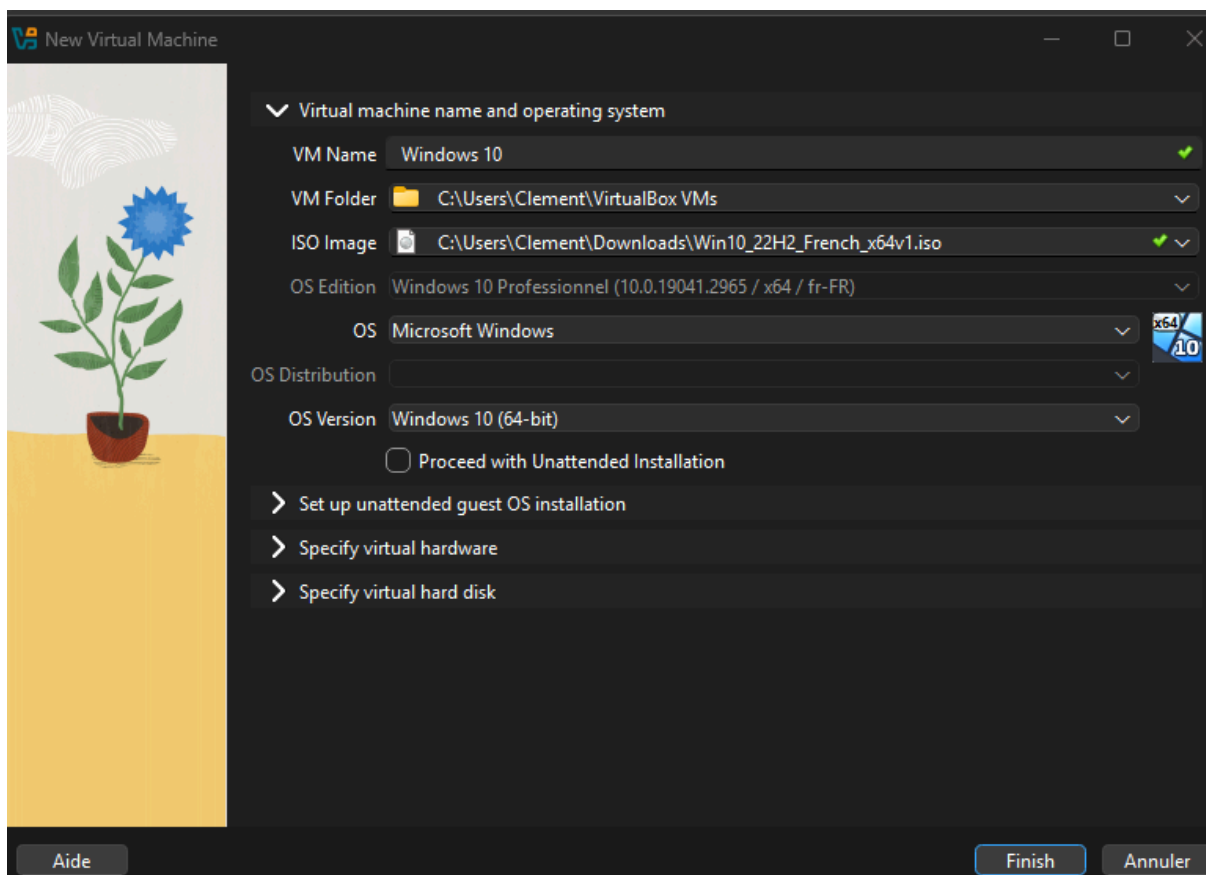
SOMMAIRE

ETAPE 1.....	3
1. Préparez la machine virtuelle Windows 10 en reprenant les éléments mentionnés dans le guide de configuration.....	3
1. Création des comptes.....	4
2. Désactivation de la protection en temps réel.....	6
3. Télécharger, décompresser, exécuter FGDUMP.....	7
4. Télécharger et installer Notepad++.....	9
5. Télécharger et décompresser vista_proba_free.zip.....	10
2. Configurez l'environnement de travail Kali selon les commandes fournies dans le document.....	11
1. Lancement de la machine virtuelle Windows avec Kali.....	12
2. Passage du QWERTY en AZERTY.....	15
3. Repérer la partition Windows.....	16
4. Accès aux fichiers Windows.....	17
ETAPE 2.....	19
3. Exécutez les différents tests proposés par l'outil John the Ripper.....	19
1 - Attaque simple.....	19
2 - Attaque par dictionnaire.....	20
3 - Attaque par dictionnaire avec règles.....	20
4 - Attaque par force brute.....	21
5 - Rockyou.....	21
6 - Affichage des mots de passe trouvés.....	21
4. Notez les identifiants trouvés et tirez les conclusions qui en découlent.....	22
ETAPE 3.....	23
5. Exécutez le test à partir d'Ophcrack.....	23
6. Proposez, d'après vos observations, plusieurs critères qui permettent d'améliorer la sécurité des mots de passe.....	32

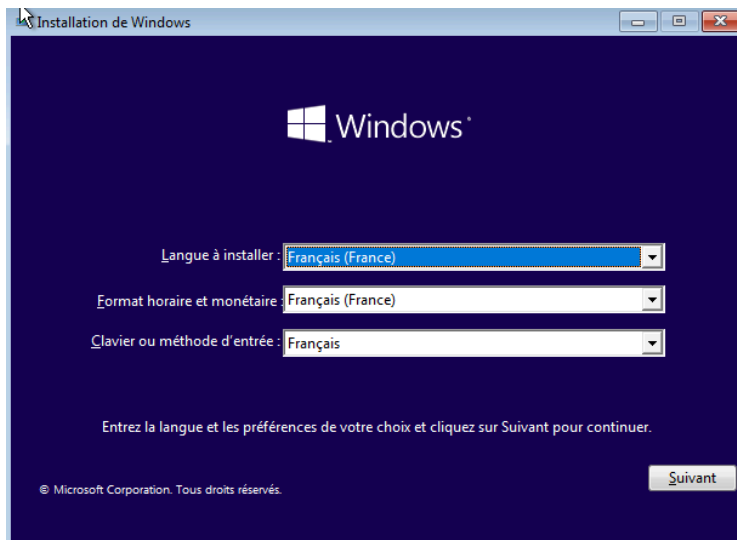
ETAPE 1

1. Préparez la machine virtuelle Windows 10 en reprenant les éléments mentionnés dans le guide de configuration

Dans un premier temps, nous allons créer une machine virtuelle Windows 10 à l'aide du logiciel de virtualisation VirtualBox.

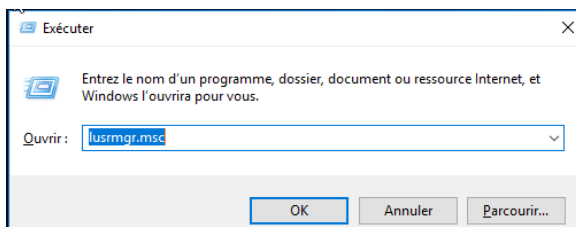


Nous procédons à l'installation de Windows 10.



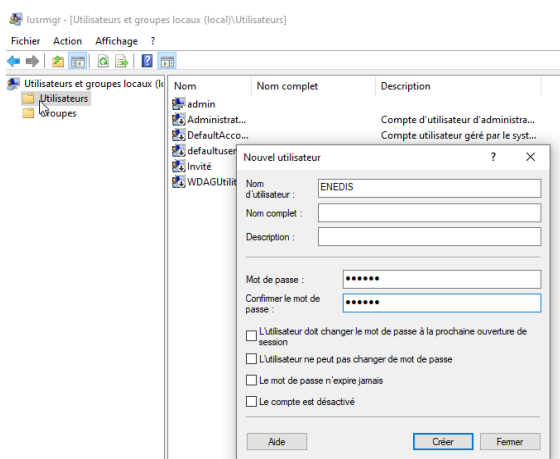
1. Création des comptes.

Nous allons créer trois comptes, ENEDIS, MSA et CLIC. Ces comptes vont être ajoutés au groupe Administrateurs afin de disposer des droits nécessaires à la réalisation des tests de sécurité. **Cette étape nous sert à créer les mots de passes que l'on va tenter de cracker plus tard dans le TP.**



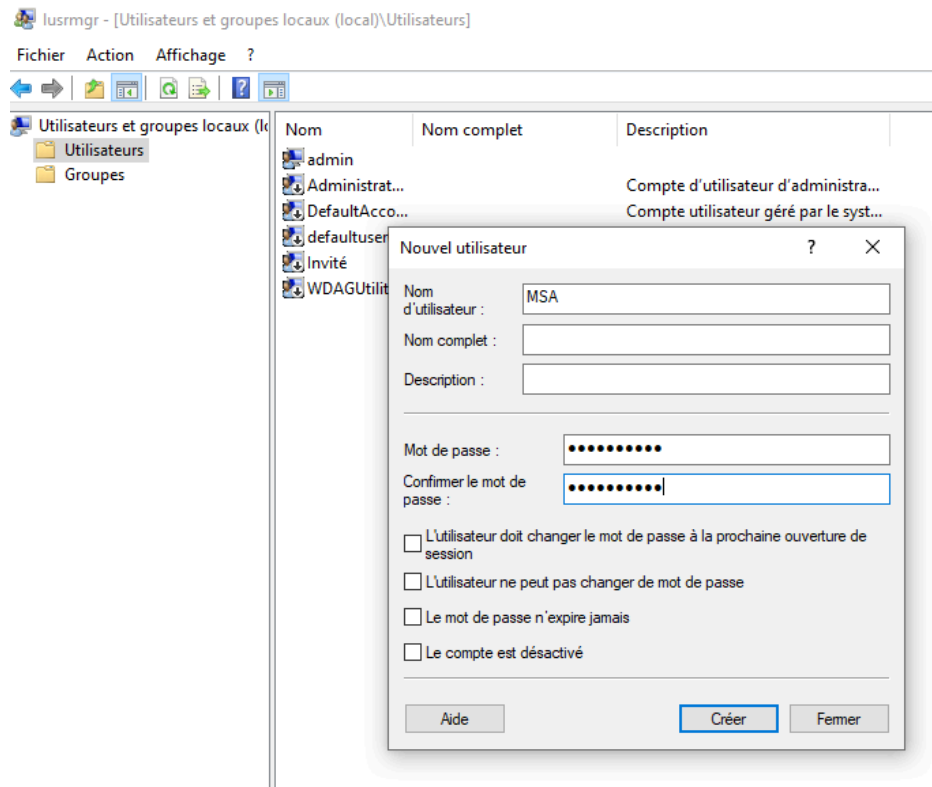
Création du compte ENEDIS

Afin de voir comment les outils de crack se comportent, nous allons faire plusieurs niveaux de robustesse, ici ENEDIS aura un mot de passe **volontairement faible**.



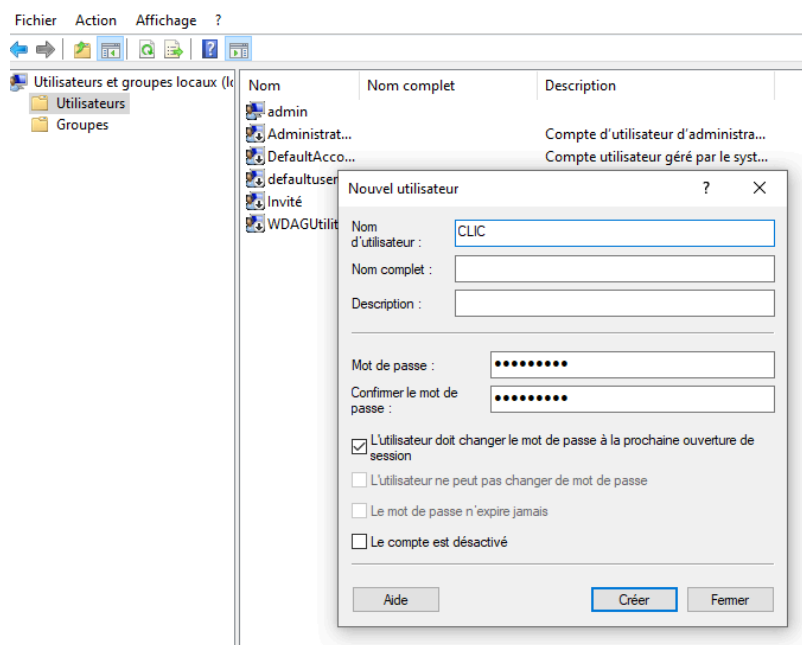
Création du compte MSA

L'utilisateur MSA quant à lui, aura un mot de passe **un peu plus sécurisé** que ENEDIS.

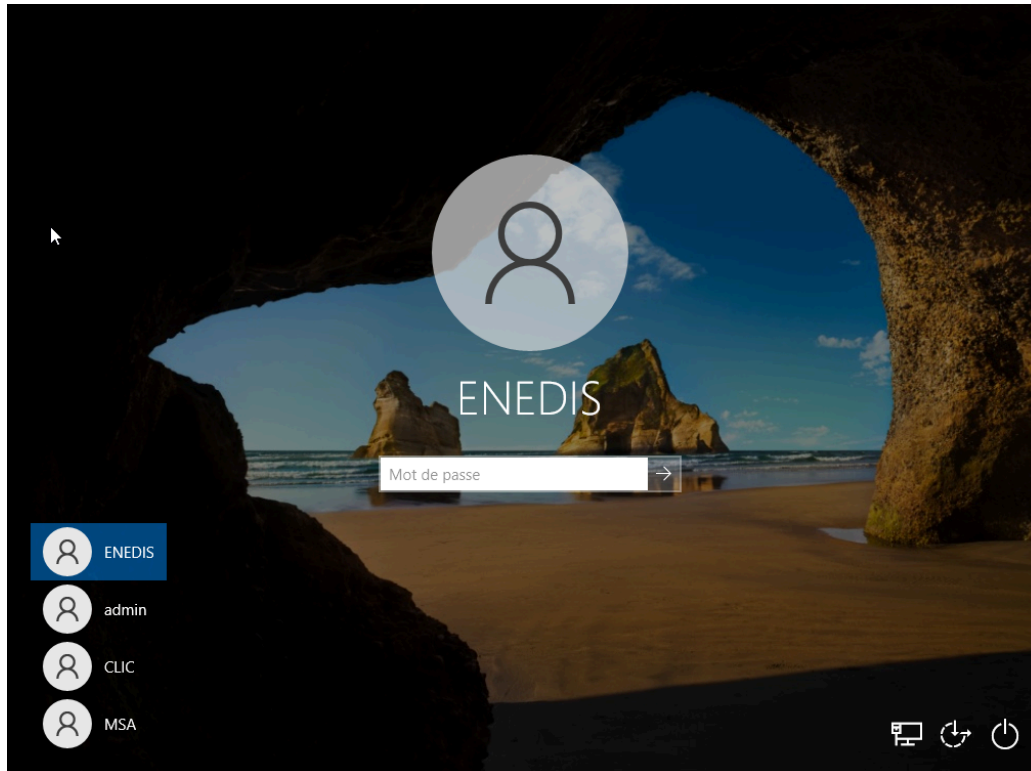


Création du compte CLIC

Pour CLIC nous choisissons d'augmenter **encore le niveau de robustesse**. Une fois les utilisateurs créés nous verrons plus tard comment les outils se débrouillent et quels mots de passe seront trouvés.

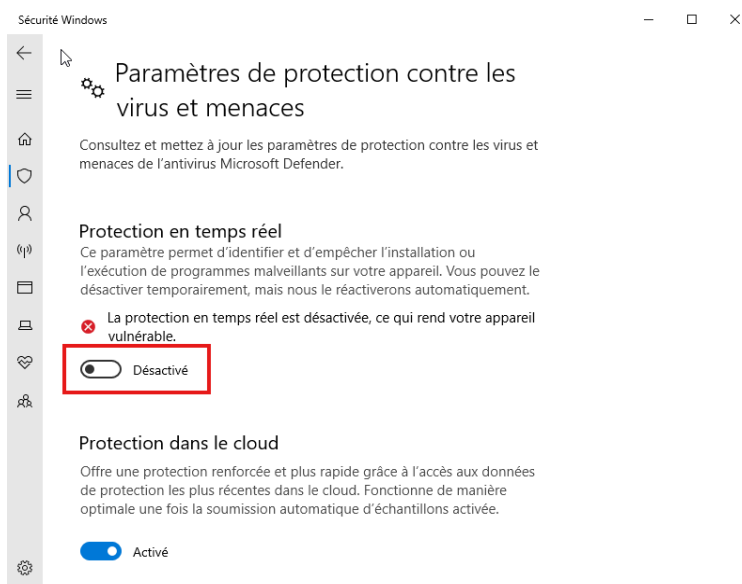


Nous nous assurons que tous les comptes ont bien été créés, ici aucun problème ENEDIS, CLIC, MSA sont bien présents.



2. Désactivation de la protection en temps réel

Afin d'exécuter l'outil FGDUMP, il faudra désactiver la protection en temps réel.
Sans ça, Windows refusera d'exécuter l'outil.



3. Télécharger, décompresser, exécuter FGDUMP

Pour commencer nous allons télécharger et exécuter l'outil FGDump. FGDump permet **d'extraire les informations de sécurité** de Windows, notamment les hashes **des mots de passe des comptes utilisateurs**. Ces mots de passe ne sont pas récupérés en clair, mais **sous forme de hashes**

Version 2.1.0 of fgdump is now available!

We now have a mailing list for all of our foofus.net tools! If you'd like to join, please see the mailman page at <http://lists.foofus.net/listinfo.cgi/foofus-tools-foofus.net>. This is a great way to get help on using the tools, report bugs, make feature requests and find out about new releases first!

Current Stable Version

fgdump 2.1.0 no source
(BZIP format, MD5Sum:687442c96d8d1854c7d65b2b8961e712) (05/07/2008)
fgdump 2.1.0 no source
fgdump 2.1.0 no source
(ZIP format, MD5Sum:a6057c3321471b8f4149e4e30200f69b) (05/07/2008)

fgdump 2.1.0 with source
(BZIP format, MD5Sum:d06b0a97481b2d19f8930715b7c143a3) (05/07/2008)
fgdump 2.1.0 with source
(ZIP format, MD5Sum:44cf98853b30767d8d0ffb595cc44c2a) (05/07/2008)

Previous Versions

fgdump 2.0.0 no source
(BZIP format, MD5Sum:e27daf1995052308d9591fbd99a3f669) (04/25/2008)
fgdump 2.0.0 no source
(ZIP format, MD5Sum:916d6ce72167ed7be07d4a3948c7f93c) (04/25/2008)

Get Now

PDFSparkWare

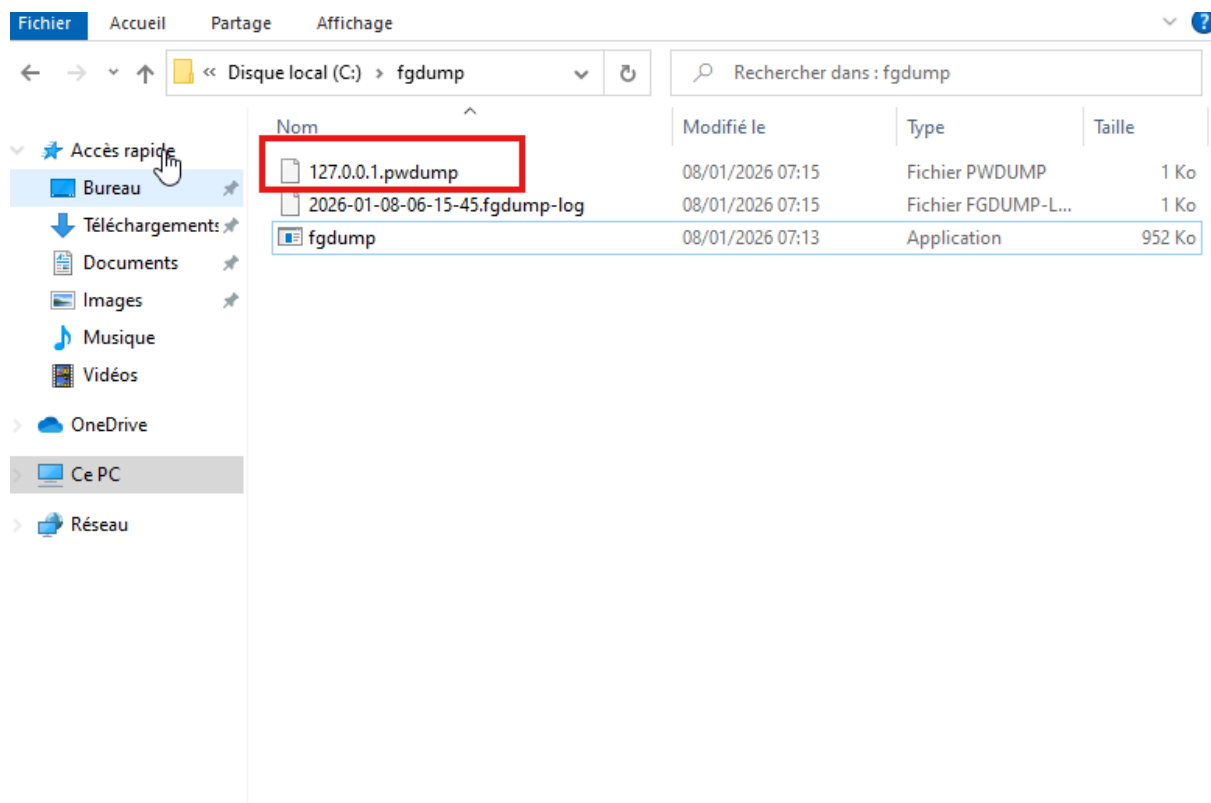
Ouvrir >

Nous lançons l'outil FGDUMP en **l'exécutant en mode administrateur**. Ici on observe l'exécution de l'outil et le début du dump des informations du système local.

```
fgDump 2.1.0 - fizzgig and the mighty group at foofus.net
Written to make j0m0kun's life just a bit easier
Copyright(C) 2008 fizzgig and foofus.net
fgdump comes with ABSOLUTELY NO WARRANTY!
This is free software, and you are welcome to redistribute it
under certain conditions; see the COPYING and README files for
more information.

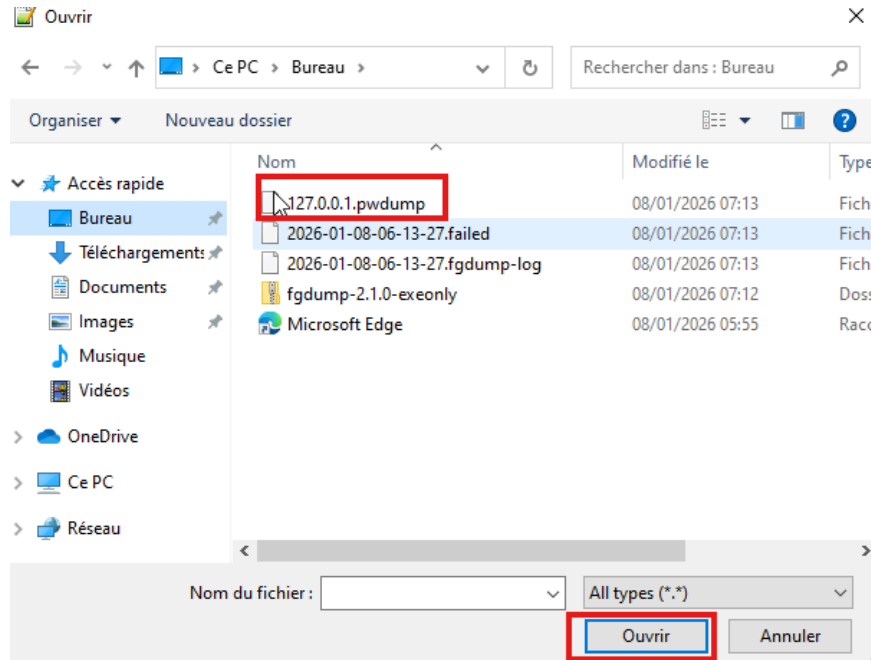
No parameters specified, doing a local dump. Specify -? if you are looking for help.
--- Session ID: 2026-01-08-06-13-27 ---
Starting dump on 127.0.0.1
-
```

L'outil a **effectué un dump local du système** afin d'extraire les informations contenues dans les fichiers SAM et SYSTEM, **générant un fichier PWDUMP**.



4. Télécharger et installer Notepad++

Nous avons téléchargé et installé l'éditeur de texte Notepad++. **Cet outil va nous permettre d'ouvrir le fichier 127.0.0.1.pwdump** généré par FGDump.



⚠ Nous ouvrons le fichier **127.0.0.1.pwdump** à l'aide de l'éditeur de texte **Notepad++** afin de visualiser les informations extraites par l'outil FGDump et de vérifier la présence des identifiants utilisateurs ainsi que des hashes de mots de passe. Cette étape est très importante, car en l'absence d'informations **il ne sera pas possible de poursuivre la suite du TP**.

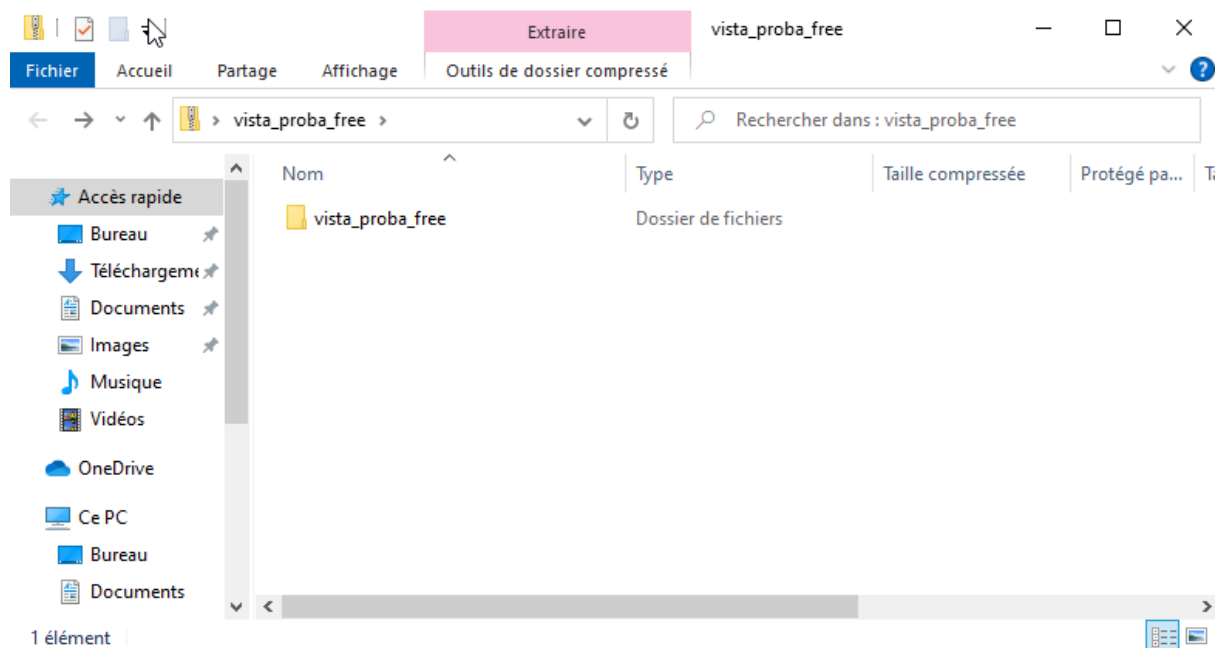
```

127.0.0.1.pwdump
1 Admin:1001:NO PASSWORD*****:97E1A410540EA18CB665D11D8D8C5B6D:::
2 Administrateur:500:NO PASSWORD*****:NO PASSWORD*****:
3 CLIC:1004:NO PASSWORD*****:FE0A975AF041E5C5679BA20EFA44127B:::
4 DefaultAccount:503:NO PASSWORD*****:NO PASSWORD*****:
5 ENEDIS:1002:NO PASSWORD*****:FC7358C0720A7395B5DC6C2B1583CEE8:::
6 Invité:501:NO PASSWORD*****:NO PASSWORD*****:
7 MSA:1003:NO PASSWORD*****:0F5A8A7CED98FE9152F29008254CE1B9:::
8

```

5. Télécharger et décompresser vista_proba_free.zip

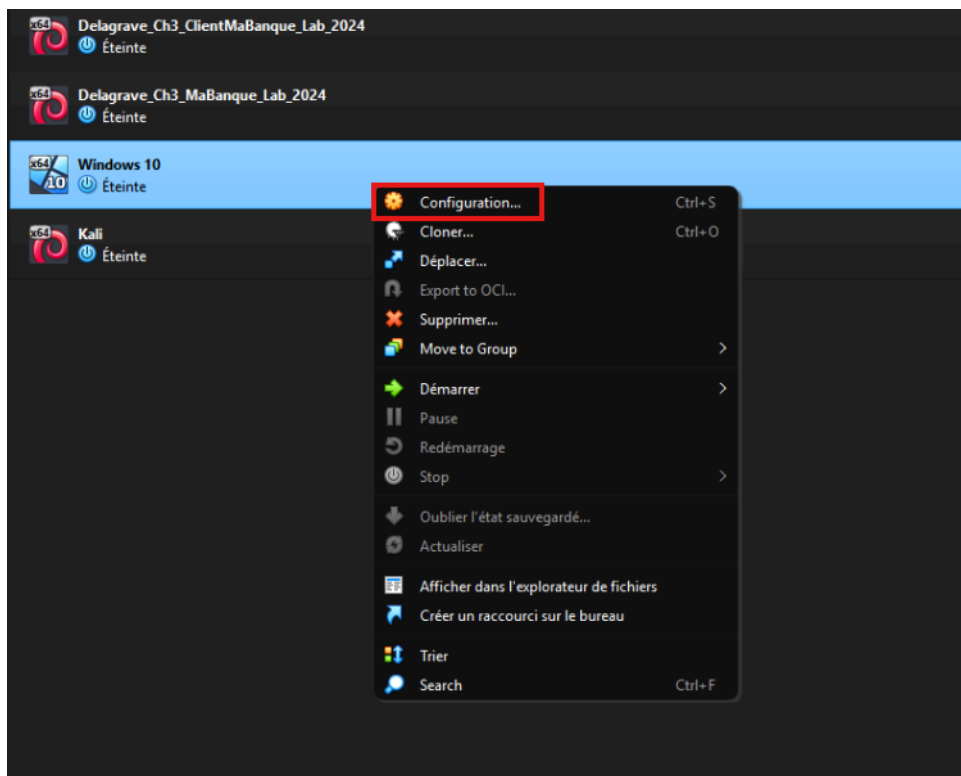
Nous avons téléchargé puis décompressé l'archive **vista_proba_free.zip**. Ceci va nous être très utile puisqu'il va nous permettre d'obtenir le dossier contenant le fichier de hash **et les tables nécessaires à la réalisation des tests avec l'outil John the Ripper** que l'on verra plus tard dans le TP.



2. Configurez l'environnement de travail Kali selon les commandes fournies dans le document.

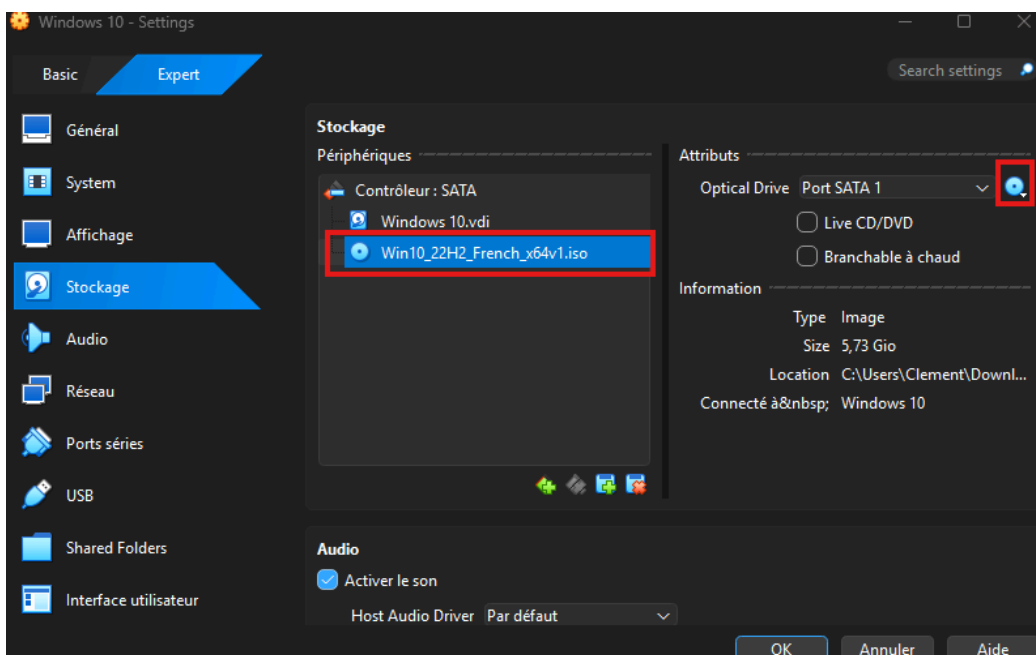
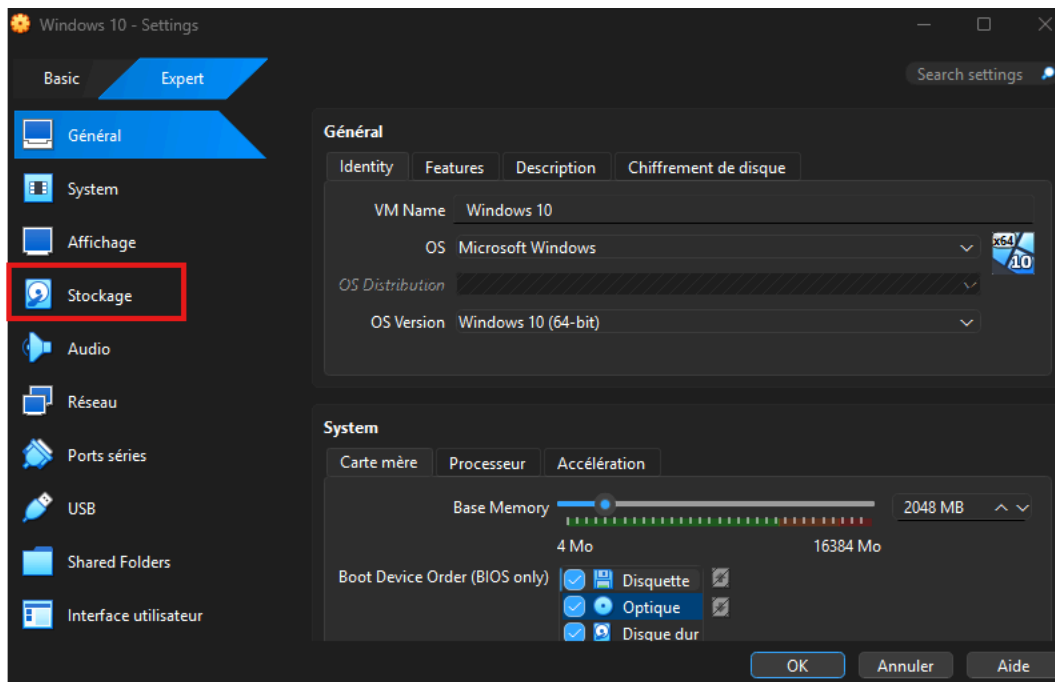
Nous allons télécharger l'image Kali afin de disposer **d'un environnement de travail dédié aux tests d'audit de mots de passe**. Cet environnement nous permettra d'utiliser des outils spécialisés tels que **John the Ripper** et **Ophcrack**. **L'objectif est de démarrer Kali par dessus Windows.**

[kali-linux-2023.1-installer-arm64.iso.torrent](#)
[kali-linux-2023.1-installer-everything-amd64.iso..>](#)
[kali-linux-2023.1-installer-i386.iso](#)
[kali-linux-2023.1-installer-i386.iso.torrent](#)
[kali-linux-2023.1-installer-netinst-amd64.iso](#)
[kali-linux-2023.1-installer-netinst-amd64.iso.to..>](#)
[kali-linux-2023.1-installer-netinst-arm64.iso](#)
[kali-linux-2023.1-installer-netinst-arm64.iso.to..>](#)
[kali-linux-2023.1-installer-netinst-i386.iso](#)
[kali-linux-2023.1-installer-netinst-i386.iso.tor..>](#)
[kali-linux-2023.1-installer-purple-amd64.iso](#)
[kali-linux-2023.1-installer-purple-amd64.iso.tor..>](#)
[kali-linux-2023.1-live-amd64.iso](#)
[kali-linux-2023.1-live-amd64.iso.torrent](#)
[kali-linux-2023.1-live-arm64.iso](#)
[kali-linux-2023.1-live-arm64.iso.torrent](#)
[kali-linux-2023.1-live-everything-amd64.iso.torr..>](#)
[kali-linux-2023.1-live-i386.iso](#)
[kali-linux-2023.1-live-i386.iso.torrent](#)

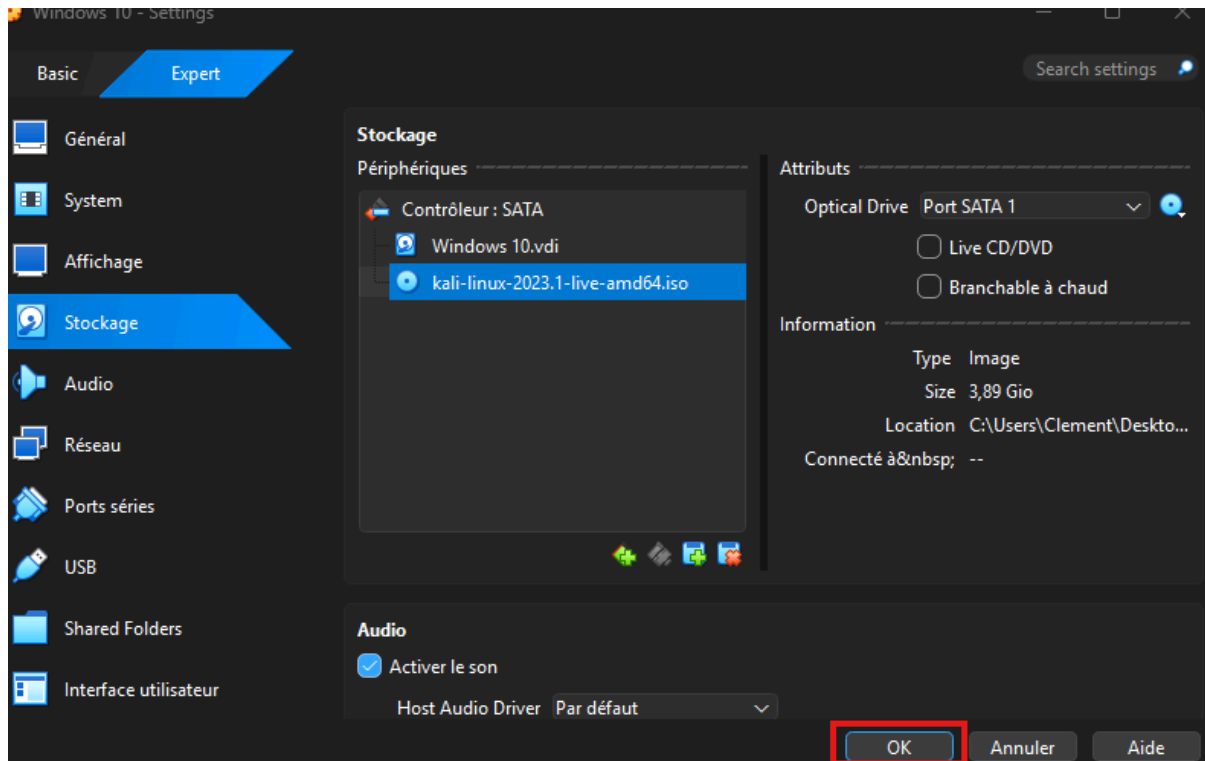


1. Lancement de la machine virtuelle Windows avec Kali

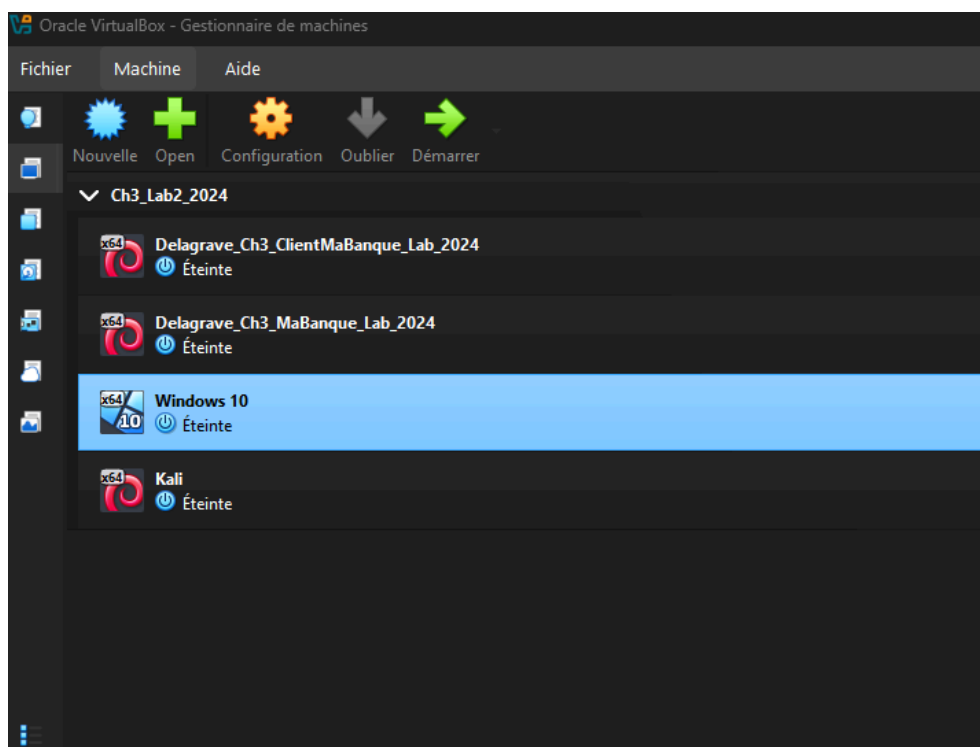
Nous allons configurer le lecteur optique de la machine virtuelle avec l'image ISO de Kali Linux. **L'objectif est de monter Kali Linux par dessus Windows et d'utiliser les outils de crack.**



Une fois l'iso Kali Linux sur le lecteur optique de la machine virtuelle, nous appuyons sur OK.



Nous allons donc lancer la machine virtuelle windows 10 afin de démarrer sur l'environnement Kali Linux et débiter nos tests.



Lors du lancement de la machine virtuelle, le menu de démarrage de Kali Linux s'affiche. À cette étape, **il faut choisir le mode Live system** afin de démarrer Kali Linux sans installation sur le disque dur de la machine. **Ce mode permet d'utiliser l'ensemble des outils de Kali Linux directement depuis l'image ISO, sans modifier le système Windows**

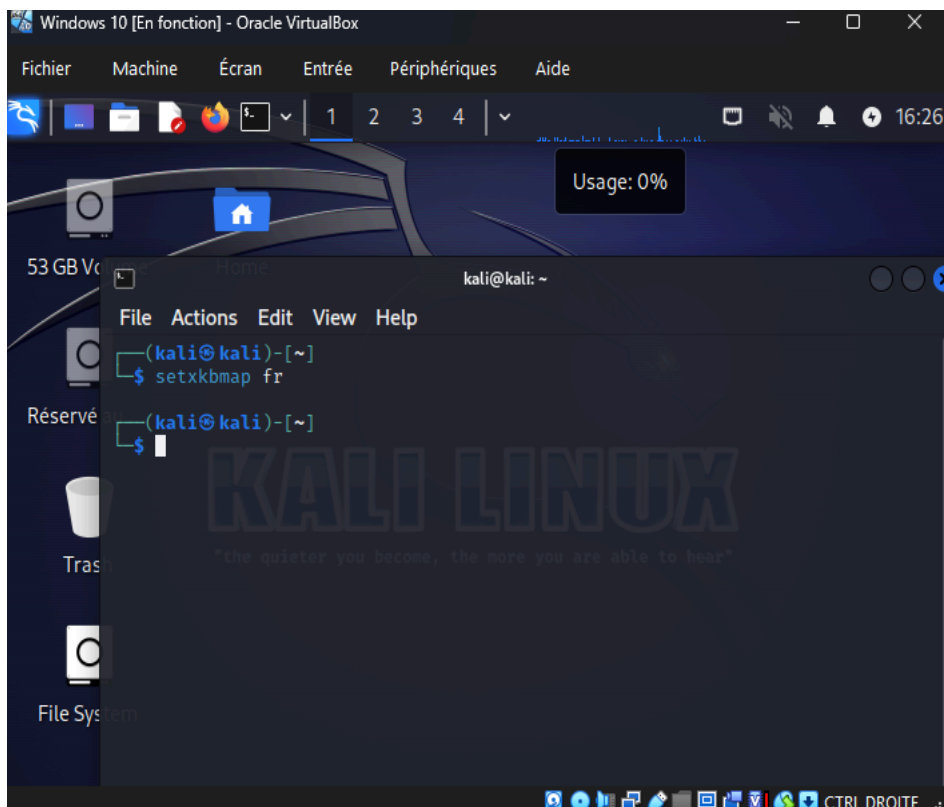
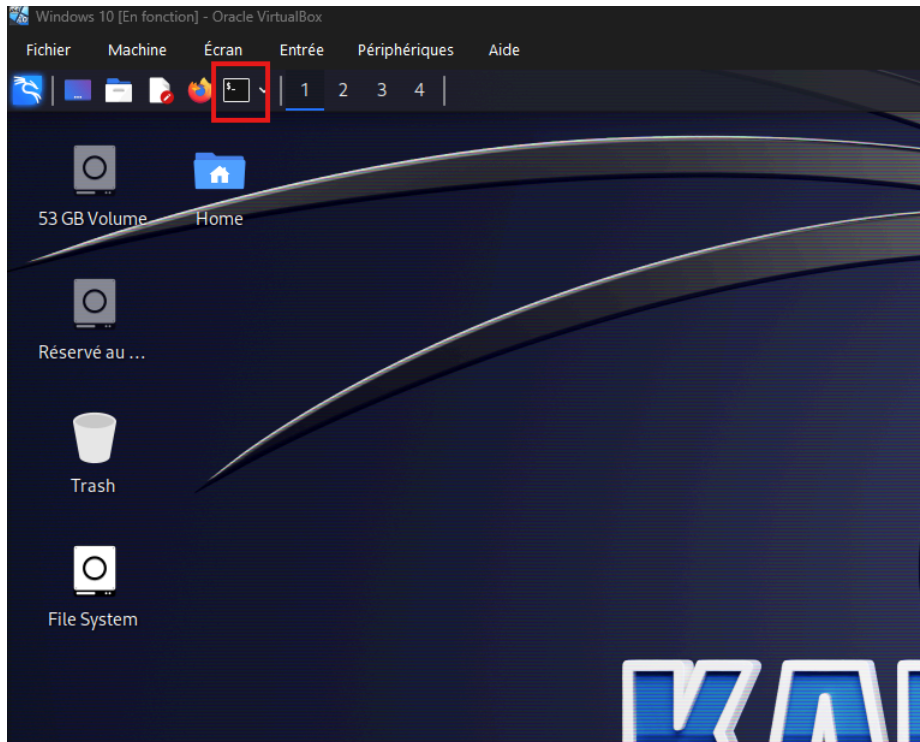


Une fois les paramétrages et l'installation terminée, nous voilà donc sur le bureau de Kali Linux.



2. Passage du QWERTY en AZERTY

Le clavier est en QWERTY nous allons donc entrer dans le terminal et insérer une commande afin de **mettre le clavier en AZERTY**.



3. Repérer la partition Windows

A présent nous allons repérer la partition Windows présente sur le disque afin de pouvoir accéder aux fichiers du système depuis Kali Linux.

```

File Actions Edit View Help
(kali㉿kali)-[~]
$ fdisk -l
fdisk: cannot open /dev/sda: Permission denied
fdisk: cannot open /dev/loop0: Permission denied

(kali㉿kali)-[~]
$ 

```

Cela nous affiche “permission refusée”, nous allons donc exécuter la commande **avec les privilèges administrateur** afin de pouvoir accéder aux informations des disques et des partitions du système.

```

$ fdisk -l
fdisk: cannot open /dev/sda: Permission denied
fdisk: cannot open /dev/loop0: Permission denied

(kali㉿kali)-[~]
$ sudo fdisk -l
Disk /dev/sda: 50 GiB, 53687091200 bytes, 104857600 sectors
Disk model: VBOX HARDDISK
Units: sectors of 1 * 512 = 512 bytes
Sector size (logical/physical): 512 bytes / 512 bytes
I/O size (minimum/optimal): 512 bytes / 512 bytes
Disklabel type: dos
Disk identifier: 0xb60e7a01

Device      Boot      Start          End      Sectors  Size Id Type
/dev/sda1   *           2048        104447       102400    50M  7 HPFS/NTF
/dev/sda2             104448    103755540    103651093   49.4G  7 HPFS/NTF
/dev/sda3      103755776    104853503     1097728    536M  27 Hidden NTFS

Disk /dev/loop0: 3.34 GiB, 3589509120 bytes, 7010760 sectors
Units: sectors of 1 * 512 = 512 bytes
Sector size (logical/physical): 512 bytes / 512 bytes
I/O size (minimum/optimal): 512 bytes / 512 bytes

(kali㉿kali)-[~]
$ 

```


4. Accès aux fichiers Windows

Nous allons accéder aux dossiers et fichiers de la partition Windows depuis l'environnement Kali Linux **afin de récupérer le fichier 127.0.0.1.pwdump** présent sur le **bureau de l'utilisateur administrateur**. Ce fichier contient les identifiants chiffrés.

Pour ce faire, il faudra monter la partition Windows afin de rendre accessibles les dossiers et fichiers du système.

Nous allons **créer un point de montage nommé /mnt/windows** afin de pouvoir y attacher la partition Windows et rendre ses fichiers accessibles depuis l'environnement Kali Linux.

```
Disk /dev/loop0: 3.34 GiB, 3589509120 bytes, 7010760 sectors
Units: sectors of 1 * 512 = 512 bytes
Sector size (logical/physical): 512 bytes / 512 bytes
I/O size (minimum/optimal): 512 bytes / 512 bytes

(kali㉿kali)-[~]
$ sudo mkdir /mnt/windows

(kali㉿kali)-[~]
$
```

Afin d'accéder aux fichiers du système Windows, **nous allons monter la partition Windows**.

```
(kali㉿kali)-[~]
$ sudo mount -o ro /dev/sda2 /mnt/windows

(kali㉿kali)-[~]
$
```

Nous allons accéder au dossier Users de la partition Windows afin d'identifier l'utilisateur administrateur et accéder à son bureau.

```
(kali㉿kali)-[/mnt/windows/Users]
$ ls
admin          Default        desktop.ini    Public
'All Users'    'Default User' ENEDIS

(kali㉿kali)-[/mnt/windows/Users]
$
```

Nous allons accéder au bureau de l'utilisateur administrateur de Windows **afin de localiser le fichier 127.0.0.1.pwdump, qui contient les hash des mots de passe nécessaires aux tests de robustesse.**

```
(kali㉿kali)-[mnt/.../Users/Admin/Desktop/fgdump]
$ ls
127.0.0.1.cachedump      2026-01-08-20-39-40.fgdump-log
127.0.0.1.pwdump         2026-01-08-20-46-06.fgdump-log
2026-01-08-20-39-40.failed fgdump.exe
```

ETAPE 2

3. Exécutez les différents tests proposés par l'outil John the Ripper

Nous commençons par lancer une attaque simple **afin de tester des mots de passe construits à partir des identifiants des utilisateurs.**

Cette méthode consiste à générer automatiquement des variantes du nom de compte comme l'ajout de chiffres ou de symboles afin de vérifier si le mot de passe est basé sur l'identifiant.

1 - Attaque simple

Cette méthode consiste à générer automatiquement des variantes du nom de compte afin de vérifier si le mot de passe est basé sur l'identifiant.

```
$ john --single --format=NT 127.0.0.1.pwdump
Warning: invalid UTF-8 seen reading 127.0.0.1.pwdump
Using default input encoding: UTF-8
Loaded 4 password hashes with no different salts (NT [MD4 256/256 AVX2 8x3])
Remaining 3 password hashes with no different salts
Press 'q' or Ctrl-C to abort, almost any other key for status
Warning: Only 8 candidates buffered for the current salt, minimum 24 needed for performance.
Almost done: Processing the remaining buffered candidate passwords, if any.
log 0:00:00:00 DONE (2026-01-08 21:28) 0g/s 261800p/s 261800c/s 785400C/s admin1902..admin1900
Session completed.
```

```
$ john --show --format=NT 127.0.0.1.pwdump
ENEDIS gete55 1002:NO PASSWORD*****:FC7358C0720A7395B5DC6C2B1583CEE8:::
Warning: invalid UTF-8 seen reading 127.0.0.1.pwdump
1 password hash cracked, 3 left
```

Avec cette attaque, le mot de passe de l'utilisateur ENEDIS a été trouvé.

2 - Attaque par dictionnaire

Une attaque par dictionnaire est réalisée à l'aide **d'une liste de mots de passe courants**.

Cette approche permet de tester rapidement **des mots de passe fréquemment utilisés par les utilisateurs**.

```
└─$ john --wordlist=/usr/share/john/password.lst --format=NT 127.0.0.1.pwdump
Warning: invalid UTF-8 seen reading 127.0.0.1.pwdump
Using default input encoding: UTF-8
Loaded 4 password hashes with no different salts (NT [MD4 256/256 AVX2 8x3])
Remaining 3 password hashes with no different salts
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:00 DONE (2026-01-08 21:34) 0g/s 354600p/s 354600c/s 1063KC/s !@#%$%
..sss
Session completed.
```

3 - Attaque par dictionnaire avec règles

Des règles de transformation sont appliquées au dictionnaire afin de générer des combinaisons plus complexes.

Cette méthode **simule les habitudes des utilisateurs** consistant à modifier légèrement un mot de passe simple pour le rendre plus fort.

```
└─$ john --wordlist=/usr/share/john/password.lst --rules --format=NT 127.0.0.1.pwdump
Warning: invalid UTF-8 seen reading 127.0.0.1.pwdump
Using default input encoding: UTF-8
Loaded 4 password hashes with no different salts (NT [MD4 256/256 AVX2 8x3])
Remaining 3 password hashes with no different salts
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:00 DONE (2026-01-08 21:37) 0g/s 7842Kp/s 7842Kc/s 23526KC/s Xxxing
..Sssing
Session completed.

(kali@kali)-[/mnt/.../Users/Admin/Desktop/fgdump]
└─$
```

4 - Attaque par force brute

Une attaque par force brute est lancée afin de tester l'ensemble des combinaisons possibles.

Cette méthode **est plus longue** mais permet d'évaluer la résistance maximale des mots de passe..

```
$ john --incremental --format=NT 127.0.0.1.pwdump
Warning: invalid UTF-8 seen reading 127.0.0.1.pwdump
Using default input encoding: UTF-8
Loaded 4 password hashes with no different salts (NT [MD4 256/256 AVX2 8x3])
Remaining 3 password hashes with no different salts
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:01:25 0g/s 35076Kp/s 35076Kc/s 105240KC/s n074wr..n07k68
0g 0:00:01:38 0g/s 35310Kp/s 35310Kc/s 105931KC/s rs29820...rs298081
0g 0:00:01:39 0g/s 35329Kp/s 35329Kc/s 105987KC/s pachial01..pachiagos
0g 0:00:01:40 0g/s 35383Kp/s 35383Kc/s 106159KC/s Cmtf..sexybisce
0g 0:00:01:41 0g/s 35404Kp/s 35404Kc/s 106225KC/s lhylovrad..lhylortj1
0g 0:00:02:53 0g/s 35953Kp/s 35953Kc/s 107861KC/s myp54sw..myp54rc
```

5 - Rockyou

L'utilisation du dictionnaire RockYou permet de réaliser une attaque par dictionnaire basée sur des mots de passe réellement utilisés.

```
(kali@kali)-[/mnt/.../Users/Admin/Desktop/fgdump]
$ sudo gunzip /usr/share/wordlists/rockyou.txt.gz
```

6 - Affichage des mots de passe trouvés

La commande suivante permet d'afficher les mots de passe trouvés par John the Ripper.

```
$ john --show --format=NT 127.0.0.1.pwdump
ENEDIS gete55 1002:NO PASSWORD*****:FC7358C0720A7395B5DC6C2B1
583CEE8:::
Warning: invalid UTF-8 seen reading 127.0.0.1.pwdump
1 password hash cracked, 3 left
```

4. Notez les identifiants trouvés et tirez les conclusions qui en découlent

À l'issue des différentes attaques réalisées à l'aide de l'outil John the Ripper, un seul mot de passe a été retrouvé.

- **Compte ENEDIS : mot de passe retrouvé**
- **Compte CLIC : mot de passe non retrouvé** (Trouvable si attaque plus longue)
- **Compte MSA : mot de passe non retrouvé** (Trouvable si attaque plus longue)

Les attaques simples, par dictionnaire avec règles et par force brute n'ont permis de compromettre qu'un seul compte utilisateur. Seulement **une attaque par force brute plus longue** aurait sûrement pu permettre de retrouver leurs mots de passe

Les résultats montrent que le mot de passe du compte ENEDIS était faible, car il a pu être retrouvé à l'aide d'attaques basées sur des méthodes courantes. Cela indique l'utilisation d'un mot de passe **insuffisamment robuste**.

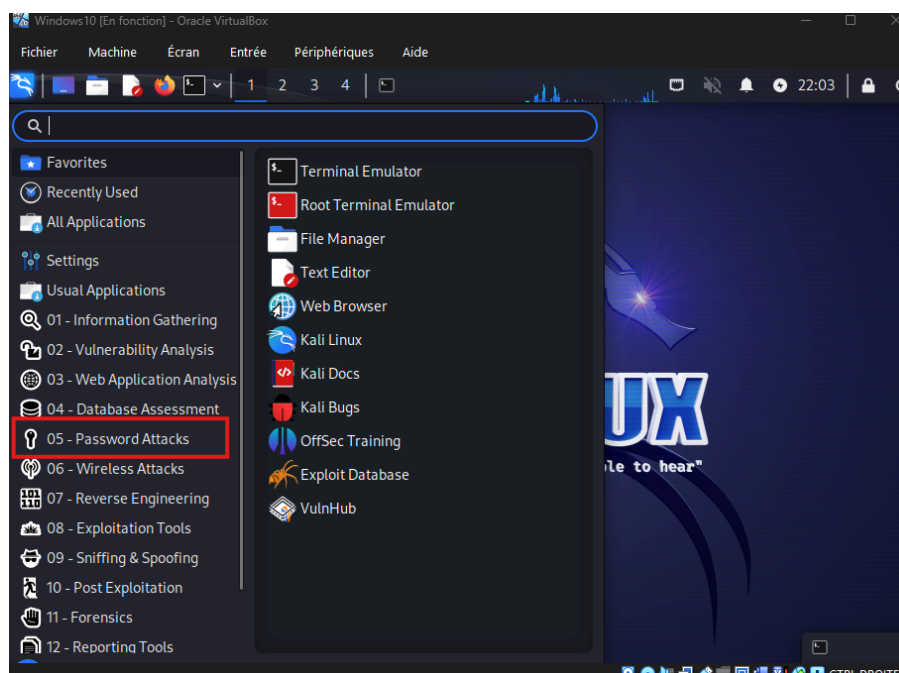
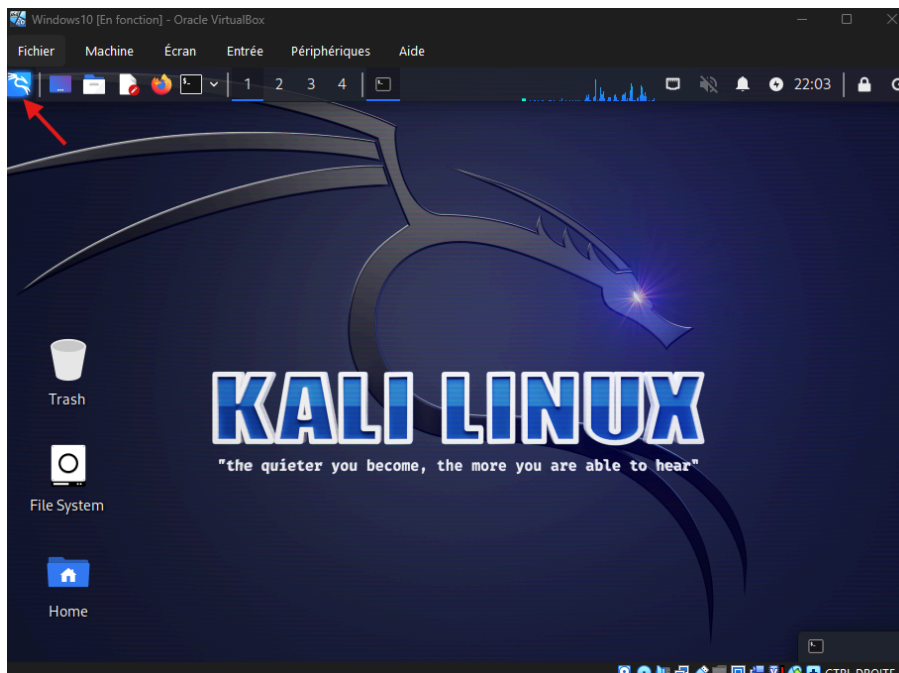
En revanche, les comptes CLIC et MSA ont résisté aux différentes attaques menées. **Leurs mots de passe ne reposent pas sur des mots du dictionnaire, ni sur des variantes simples de l'identifiant, ce qui témoigne d'un meilleur niveau de sécurité.**

Ces tests mettent en évidence l'importance de choisir des mots de passe complexes, non liés à des informations personnelles, et suffisamment longs afin de limiter les risques de compromission.

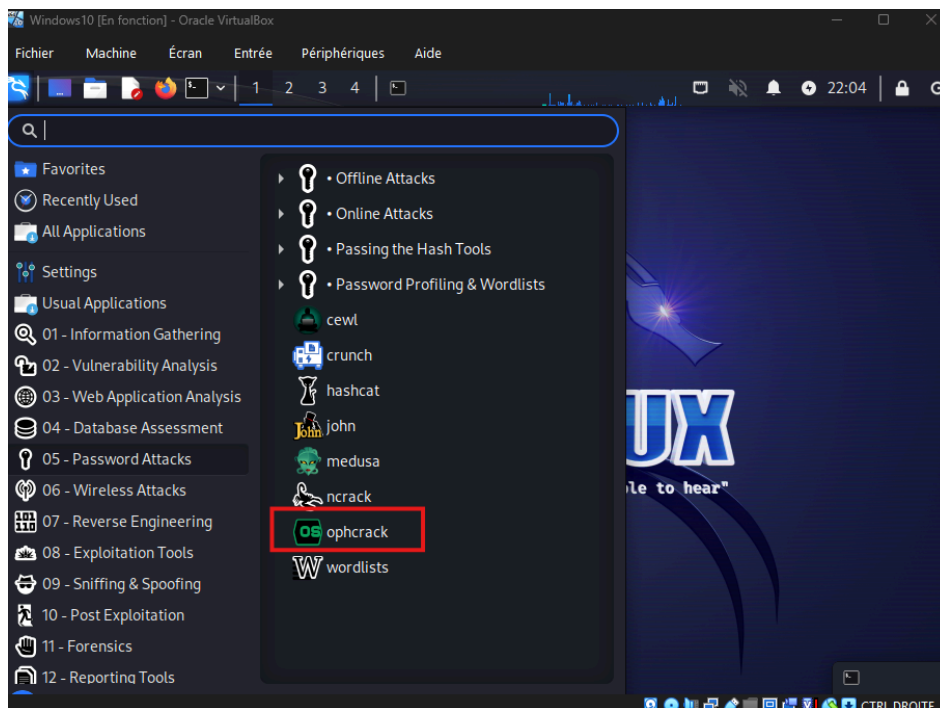
ETAPE 3

5. Exécutez le test à partir d'Ophcrack

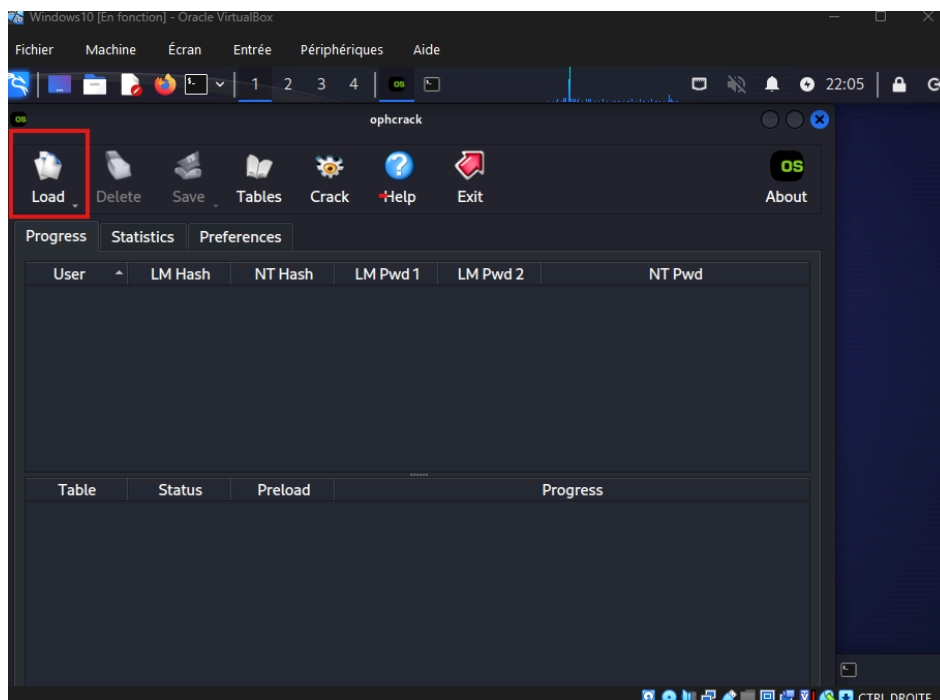
Il faut maintenant exécuter l'outil **Ophcrack** depuis Kali Linux afin de réaliser le test de récupération des mots de passe à l'aide de tables arc-en-ciel, en utilisant la table vista_proba_free précédemment installée.



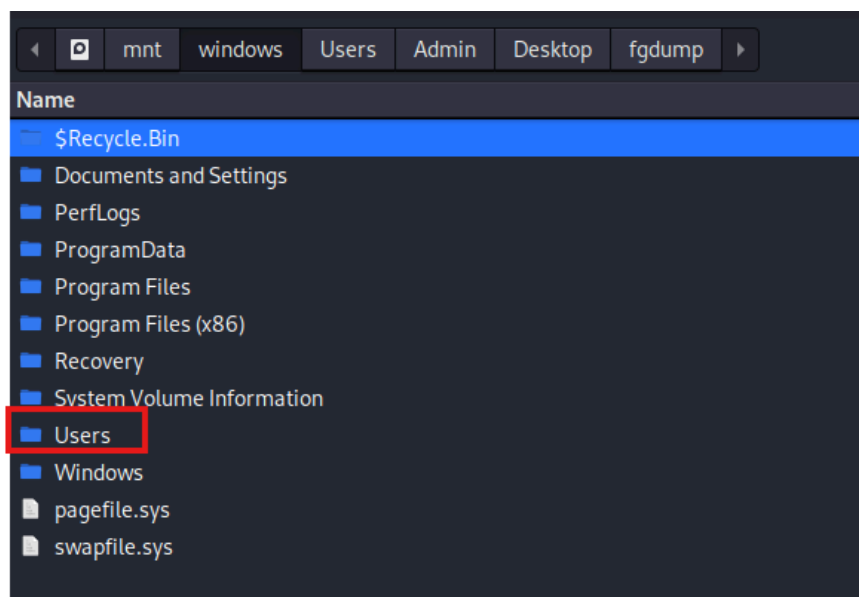
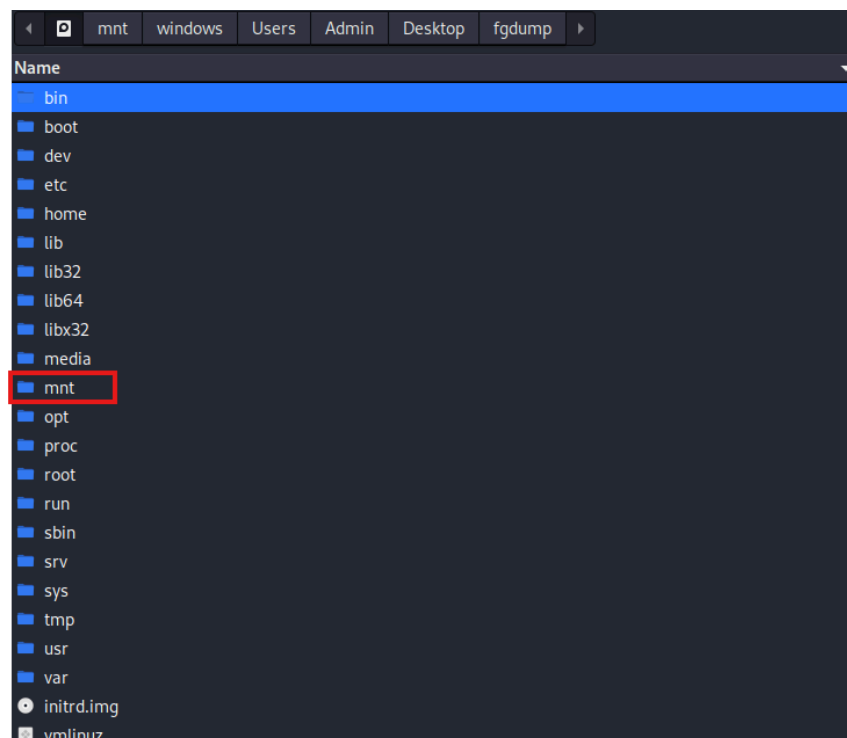
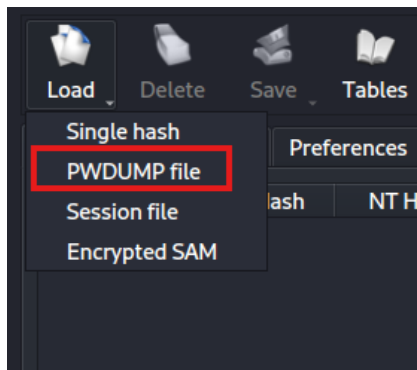
Nous sélectionnons ophcrack.



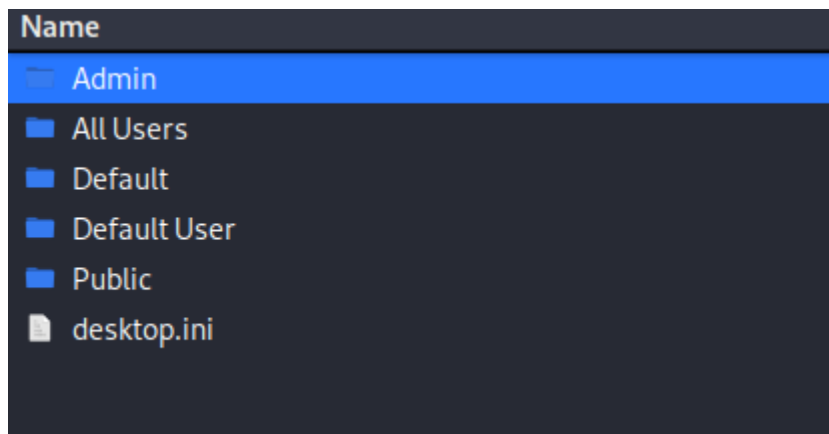
Ensuite nous allons charger dans Ophcrack le fichier **127.0.0.1.pwdump**, qui a été généré au début du TP et qui contient les identifiants des utilisateurs ainsi que les hashes des mots de passe associés.



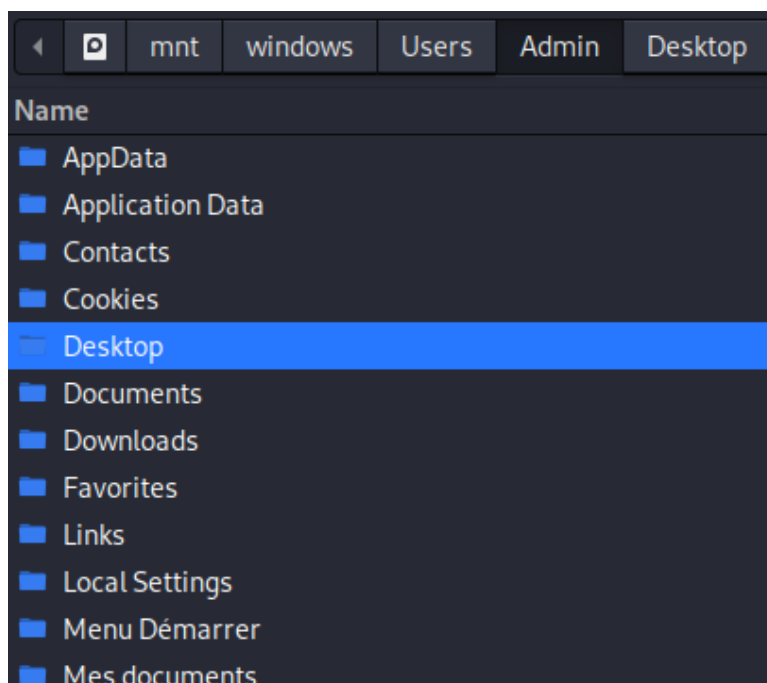
PWDUMP file



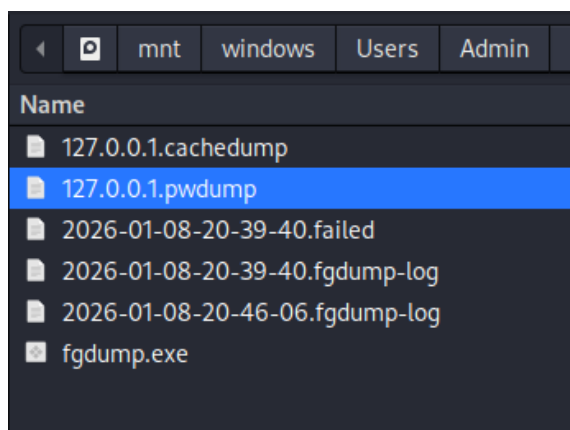
Admin



Desktop



Nous avons trouvé le fichier 127.0.0.1.pwdump.



Progress Statistics Preferences					
User	LM Hash	NT Hash	LM Pwd 1	LM Pwd 2	NT Pwd
Admin		97E1A4105...			
Administrat...		31d6cfe0d1...		empty	
CLIC		FE0A975AF...			
DefaultAcc...		31d6cfe0d1...		empty	
ENEDIS		FC7358C07...			
Invit		31d6cfe0d1...		empty	
MSA		0F5A8A7C...			
Table Status Preload Progress					

Récupération de la table vista_proba_free

Dans cette étape, nous allons récupérer la table arc-en-ciel vista_proba_free depuis la partition Windows et l'intégrer dans Kali. Pour rappel une table arc-en-ciel est un fichier qui contient des mots de passe déjà calculés à l'avance. Lorsqu'un hash est récupéré sur un système, l'outil peut le comparer directement avec ceux présents dans la table.

```

(kali㉿kali)-[/mnt/.../Users/Admin/Desktop/fgdump]
$ sudo mkdir -p /usr/share/ophcrack/tables

(kali㉿kali)-[/mnt/.../Users/Admin/Desktop/fgdump]
$ sudo cp -r /mnt/windows/Users/Admin/Desktop/vista_proba_free /usr/share/ophcrack/tables/

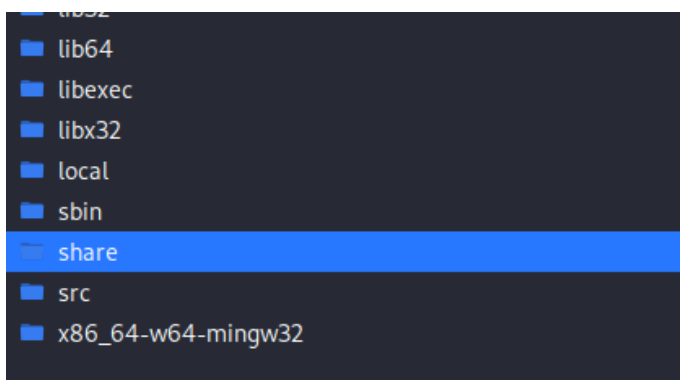
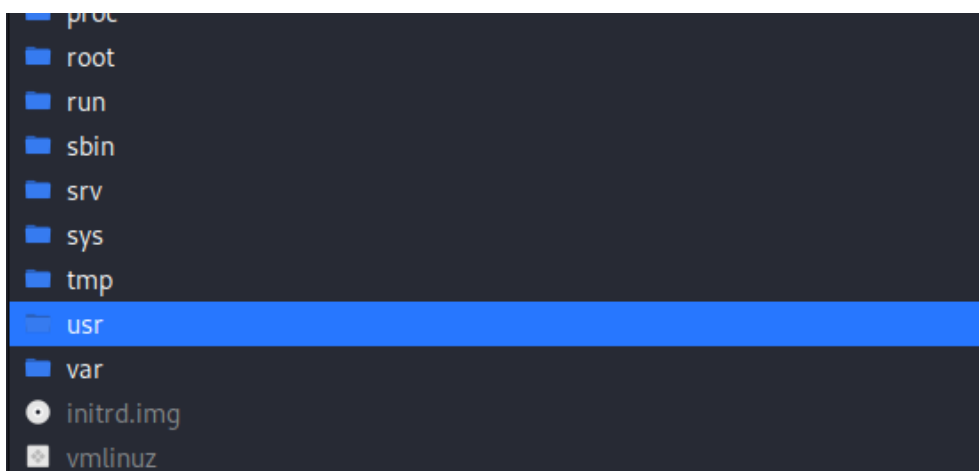
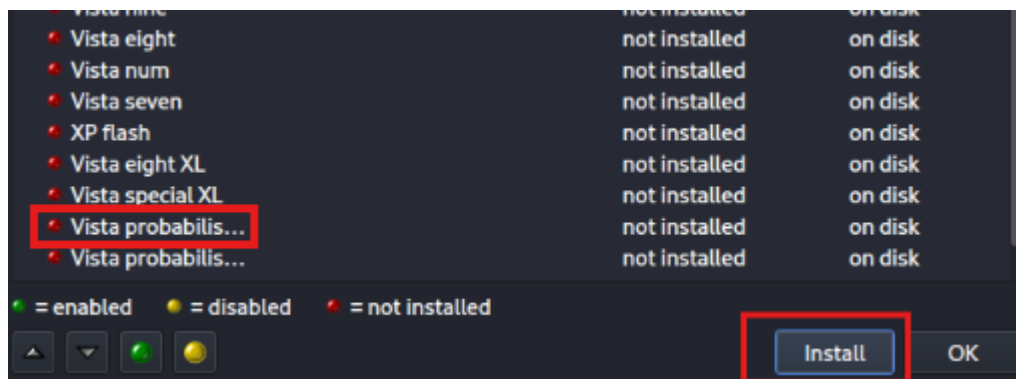
(kali㉿kali)-[/mnt/.../Users/Admin/Desktop/fgdump]
$ ls /usr/share/ophcrack/tables
vista_proba_free

```

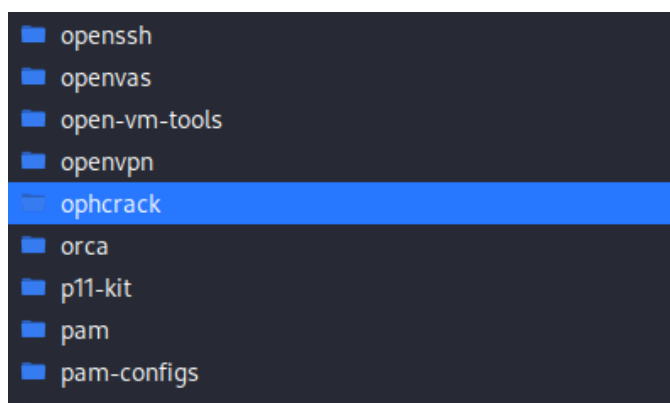
Revenons sur OPHCrack, maintenant que la table a été intégrée.

Load	Delete	Save	Tables	Crack
Progress Statistics Preferences				
User	LM Hash	NT Hash	LM	
Admin		97E1A4105...		
Administrat...		31d6cfe0d1...		
CLIC		FE0A975AF...		
DefaultAcc...		31d6cfe0d1...		
ENEDIS		FC7358C07...		
Invit		31d6cfe0d1...		
MSA		0F5A8A7C...		

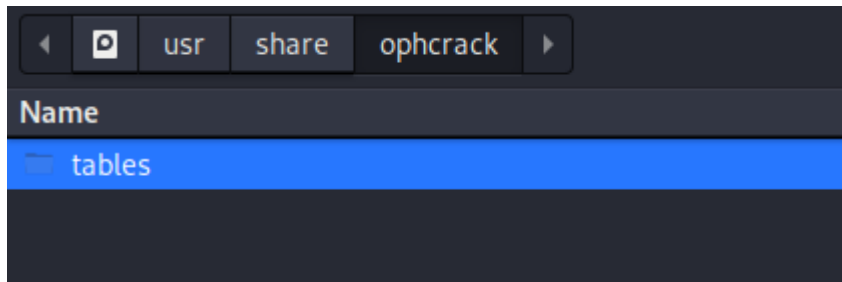
Nous allons à présent installer la table vista.



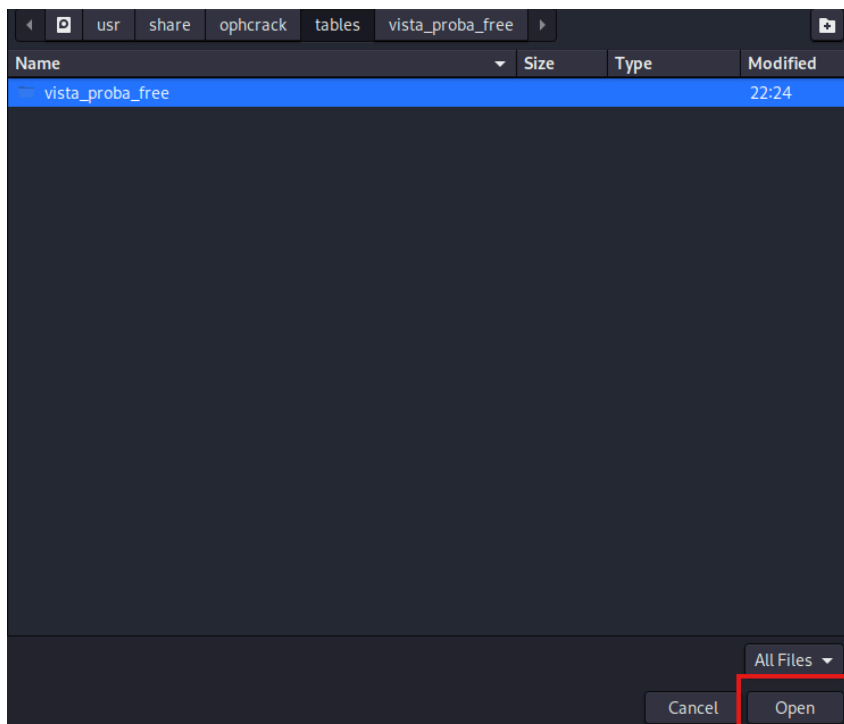
Sélectionnons ici ophcrack.



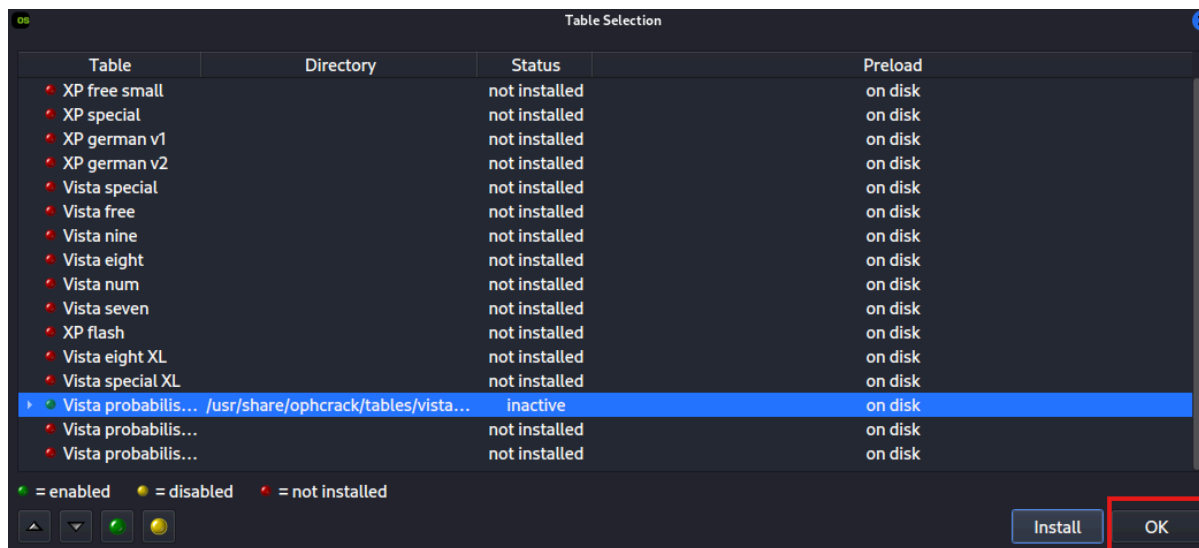
Puis tables.



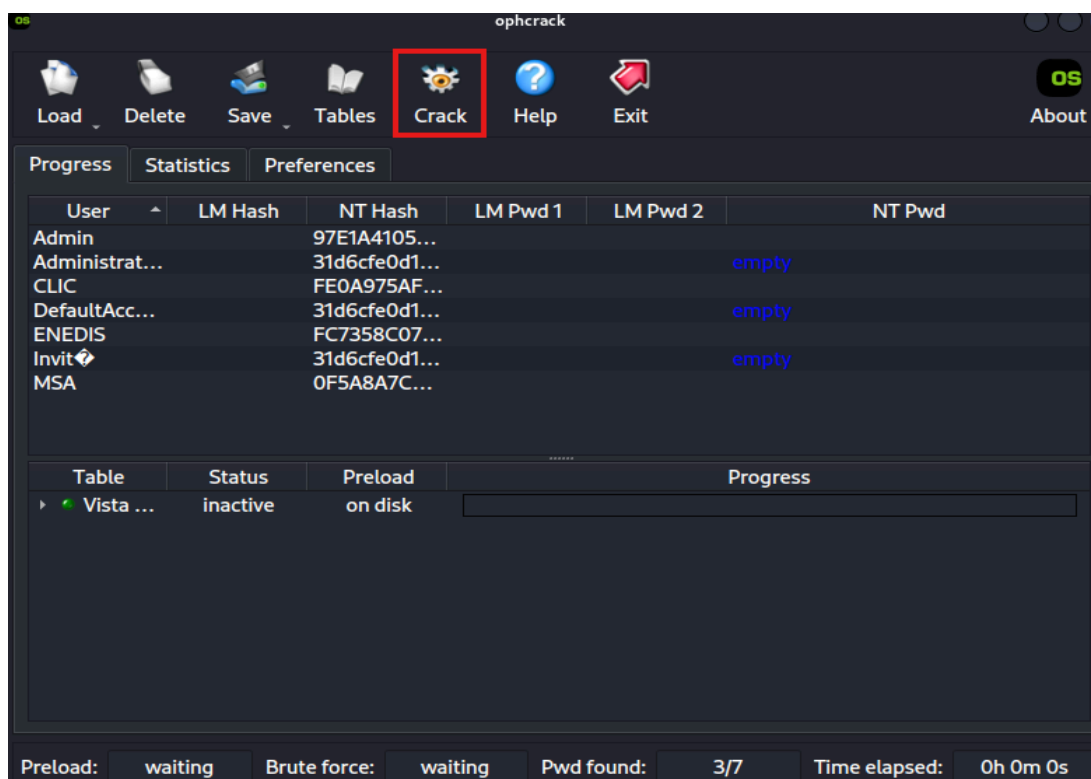
Nous avons **trouvé** la table.



À ce stade, la table arc-en-ciel vista_proba_free est correctement installée et reconnue par Ophcrack. **L'outil est désormais prêt à exploiter cette table.**



Il est alors possible de lancer le processus de récupération des mots de passe en démarrant l'attaque à l'aide du bouton Crack.



Résultat du crack :

Lors de l'exécution du crack avec Ophcrack et la table arc-en-ciel vista_proba_free, **les mots de passe des comptes CLIC et ENEDIS ont pu être récupérés.**

Le crack n'ayant pas été mené jusqu'à son terme, **il est possible que le mot de passe du compte MSA aurait pu être retrouvé si l'attaque avait été poursuivie plus longtemps.** Ce résultat met en évidence que l'efficacité d'Ophcrack dépend **à la fois de la table utilisée et du temps laissé à l'outil** pour parcourir l'ensemble des correspondances possibles.

The screenshot shows the Ophcrack application interface. At the top, there is a menu bar with icons for Load, Delete, Save, Tables, Stop, Help, Exit, and an OS icon. Below the menu bar, there are tabs for Progress, Statistics, and Preferences. The main area displays a table with the following columns: User, LM Hash, NT Hash, LM Pwd 1, LM Pwd 2, and NT Pwd. The table lists several users, including Admin, Administrat..., CLIC, DefaultAcc..., ENEDIS, Invit, and MSA. The NT Pwd column shows the recovered passwords for CLIC (vetegri7) and ENEDIS (gete55), which are highlighted with red boxes. Below the main table, there is a section for the current table being used, showing 'Vista ...' with a status of 'active' and a progress of '62% in RAM'. At the bottom, there is a status bar with fields for Preload (done), Brute force (done), Pwd found (5/7), and Time elapsed (0h 27m 2s).

User	LM Hash	NT Hash	LM Pwd 1	LM Pwd 2	NT Pwd
Admin		97E1A4105...			
Administrat...		31d6cfe0d1...			
CLIC		FE0A975AF...			vetegri7
DefaultAcc...		31d6cfe0d1...			empty
ENEDIS		FC7358C07...			gete55
Invit		31d6cfe0d1...			empty
MSA		0F5A8A7C...			

Table	Status	Preload	Progress
Vista ...	active	62% in RAM	

Preload: done Brute force: done Pwd found: 5/7 Time elapsed: 0h 27m 2s

6. Proposez, d'après vos observations, plusieurs critères qui permettent d'améliorer la sécurité des mots de passe.

D'après nos observations issues des tests réalisés avec les outils John the Ripper et Ophcrack, **plusieurs critères permettent d'améliorer significativement la sécurité des mots de passe**. Tout d'abord, il est essentiel d'utiliser des mots de passe **suffisamment longs**, idéalement au moins 12 caractères, afin de limiter l'efficacité des attaques par force brute qui deviennent exponentiellement plus coûteuses en temps et en ressources. Ensuite il faut absolument éviter les mots de passe **basés sur l'identifiant, le nom de l'utilisateur ou toute information personnelle** facilement devinable, car ces éléments sont les **premières cibles des attaques par dictionnaire**.

Il est également recommandé de combiner différents types de caractères : lettres majuscules et minuscules, chiffres, ainsi que caractères spéciaux comme !, @, ou #, ce qui **augmente considérablement la robustesse et rend les attaques plus complexes**. Par ailleurs, il faut éviter l'utilisation de mots de passe courants ou présents dans des dictionnaires, ainsi que leurs variantes simples car John the Ripper excelle dans ce type d'attaques.

Mieux vaut privilégier des mots de passe non présents dans les tables arc-en-ciel, comme ceux ne reposant pas sur des mots usuels mais plutôt sur des phrases aléatoires ou des combinaisons imprévisibles, rendant inefficaces les outils comme Ophcrack qui s'appuient sur ces tables. **Un changement régulier de mots de passe est nécessaire, par exemple tous les 6 mois**.

Enfin, les utilisateurs **doivent être sensibilisés** aux bonnes pratiques de sécurité afin de réduire les risques liés aux mots de passe faibles.

Ces mesures renforcent globalement la résistance face aux attaques par dictionnaire, par tables arc-en-ciel et par force brute.